

# Stop API abuse from tampered mobile apps

Runtime attestation + request-bound signing, delivered as a two-line SDK integration with a bundled server-side verifier. Built for banking security review.

- Runtime Attestation
- Request Signing
- Gradle + OkHttp
- OWASP MASVS
- PSD2 · PCI

THE 30-SECOND VERSION

## Assume the API is public. Make abuse non-actionable.

Static analysis of any banking APK exposes every endpoint, schema, and embedded key — this cannot be fixed by hiding. We don't try to. We move trust to your server: the app proves its integrity, receives only short-lived request-bound credentials, and your backend rejects everything else. A captured request cannot be replayed or forged at scale.

**WHAT WE DELIBERATELY DO NOT SELL**

"Invisible" or "un-reverse-engineerable" APIs. That claim is false on mobile and fails a bank security review. OWASP: it is *impossible to prevent static analysis*.

**WHAT WE SELL — AND CAN DEFEND**

A leaked endpoint or key is **useless to anything but your genuine, unmodified app**. Same architecture banks already accept under PSD2 & PCI. Candor passes due diligence.

**<1 ms**

added latency per request

**2 lines**

to integrate (plugin + client)

**Fail-closed**

no valid attestation → rejected

**Bundled**

server verifier included

LAYERED DEFENSE

|                                 |                                                                                              |                  |
|---------------------------------|----------------------------------------------------------------------------------------------|------------------|
| Server enforcement              | authN/Z · short-lived revocable tokens · rate limits · anomaly detection                     | DURABLE CONTROL  |
| Attestation (server-verified)   | Play Integrity / challenge-response → risk scoring · blocks repackaged apps, emulators, bots | SECURITY CONTROL |
| Cryptographic (client → server) | per-request signature bound to body + nonce · JIT secrets · dynamic pinning                  | SECURITY CONTROL |
| Obfuscation (client)            | endpoint-table + NDK string encryption · deters commodity static analysis                    | FRICTION ONLY    |

Why banks buy this

- Maps to controls a PCI QSA / PSD2 auditor already verifies
- No secret ships in the binary — central rotation, no app release
- Honest threat model survives technical due diligence

What you integrate

- One Gradle plugin + one OkHttp client factory call
- Drop-in server verifier (Node / Java / Go)
- Defined degraded mode for non-GMS / offline devices